The key point is that retrieval is the last step where access control can be enforced reliably. If unauthorized data is never accessed, it cannot be leaked, summarized, or analyzed by the model. Authorization after retrieval is already too late. This leads directly to the architectural principle that governs ACME's RAG systems: *authorization must occur before retrieval, not after generation*.

17.4.3 From architectural principle to concrete flow

Figure 17.4 illustrates how ACME applied the architectural boundary introduced earlier in Figure 17.2 to a retrieval-augmented generation system. The overall service structure remains the same: the application receives a request, builds context, calls on an LLM, and returns a response. The key change is where and how authorization impacts retrieval.

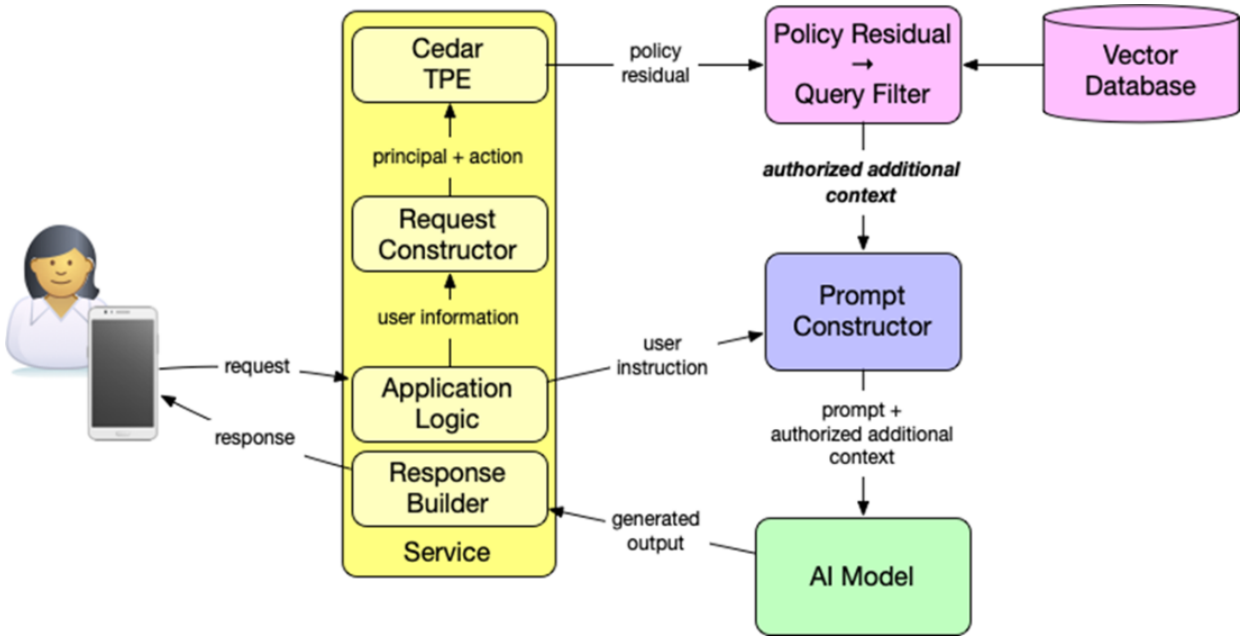


Figure 17.4 Authorization before retrieval in RAG systems. Authorization constrains retrieval rather than generated output. By enforcing access before data is retrieved, the system ensures that the language model operates only on authorized inputs, making information leakage structurally impossible rather than merely discouraged.

In this design, the application logic first uses a request constructor to build a structured authorization request from user information, including the principal and the requested action. That request is then passed to the Cedar component (see the sidebar to this section for more on this), which evaluates